



Escuela de Ingeniería y Ciencias
Ingeniería en Ciencias de Datos y Matemáticas

Etapa 1 del reto: Gestor de Identidades

Reporte Ejecutivo

Estudiantes y matrículas

Alberto Palomino Carvajal – A01571511
Carlos Cuéllar Solís – A01571619
Daniel Rodríguez Gallegos – A01285849
Leonardo Albarran Valdes – A01571750
Luis Javier Jacobo Morimoto – A01571679
Viviana Carrizales Luna – A01286191

Equipo: 2 Grupo: MA2006B.602

Profesores:

Raúl Gómez Muñoz Daniel Otero Fadul Alberto F. Martínez

Socio Formador: Casa Monarca – Ayuda Humanitaria al Migrante, A.C.

Monterrey, Nuevo León – 15 de mayo de 2026

Índice de Contenidos

0.1. Índice de Contenidos	1
0.2. Resumen Ejecutivo	1
0.2.1. Qué problema se resolvió	1
0.2.2. Objetivos iniciales	1
0.2.3. Qué se desarrolló	1
0.2.4. Resultado logrado	2
0.2.5. Impacto principal	2
0.2.6. Estado actual	2
0.3. Objetivos vs Resultados	2
0.3.1. Qué se cumplió	2
0.3.2. Qué se modificó o adaptó con respecto a los objetivos iniciales	2
0.3.3. Pendientes para siguientes versiones	2
0.4. Solución Implementada	3
0.4.1. Qué hace la aplicación realmente	3
0.4.2. Usuarios que la utilizan e impacto generado	3
0.4.3. Alcance final de la aplicación.	3
0.5. Impacto de Negocio	3
0.5.1. Ahorro generado (tiempo/dinero)	3
0.5.2. Incremento en productividad	3
0.5.3. Reducción de errores o riesgos	3
0.6. Lecciones y Hallazgos	4
0.6.1. Qué funcionó bien	4
0.6.2. Qué se puede mejorar	4
0.6.3. Riesgos detectados	4
0.7. Estado Actual y Próximos Pasos	4
0.7.1. Estado:	4
0.7.2. Recomendaciones:	4
0.8. Referencias	5
0.9. Inteligencia artificial	5

Resumen Ejecutivo

Qué problema se resolvió

De acuerdo con Casa Monarca (s.f.), Casa Monarca, como organización sin fines de lucro que atiende a población migrante y refugiada, gestionaba la identidad de sus colaboradores de forma completamente manual y sin ningún respaldo criptográfico. No existía un mecanismo formal para determinar quién tenía acceso a qué recursos, ni una forma de revocar ese acceso cuando alguien dejaba la organización. Esto representaba un riesgo real: cualquier persona con credenciales vigentes podía seguir operando dentro del sistema sin que nadie lo detectara. Tampoco existía trazabilidad de las acciones, lo que dificultaba cualquier auditoría y ponía en riesgo el cumplimiento de la Ley Federal de Protección de Datos Personales.

Objetivos iniciales

Desde el inicio, el proyecto se planteó resolver cuatro necesidades concretas: dar de alta identidades digitales de forma controlada, revocarlas cuando fuera necesario, eliminarlas definitivamente al concluir una relación laboral y dejar un rastro auditable de cada una de esas acciones. Todo esto, alineado con los Derechos ARCO y las obligaciones legales mexicanas en materia de datos personales. Además, se buscaba que la solución fuera accesible para personas sin formación técnica y que no interrumpiera los procesos administrativos que la organización ya tenía en funcionamiento.

Qué se desarrolló

Se construyó una API REST con FastAPI que centraliza todo el ciclo de vida de las identidades digitales. Cada colaborador recibe un par de llaves RSA de 2048 bits y un certificado X.509 firmado por una Autoridad

Certificadora propia del sistema. Las claves privadas nunca se almacenan en texto plano: se cifran con Fernet antes de llegar a la base de datos. El acceso se gestiona mediante JWT con sesiones de ocho horas, y la arquitectura respeta una jerarquía de cuatro roles: Admin, Coordinator, Operative y External. Todo esto se acompaña de un dashboard web embebido, funcional y visualmente cuidado, que permite operar el sistema sin necesidad de conocer la API.

Resultado logrado

Actualmente, el sistema ofrece un control real y verificable sobre quién pertenece a la organización y qué nivel de acceso posee. Se pueden emitir certificados con vigencia configurable, revocarlos ante cualquier incidente, renovarlos sin perder el historial y crear usuarios efímeros para accesos temporales. Cada acción —desde un inicio de sesión hasta una baja definitiva— queda registrada en un log de auditoría con actor, fecha y descripción. La base de datos nunca expone material criptográfico sensible, y el administrador tiene visibilidad total del sistema desde una sola interfaz.

Impacto principal

El impacto más significativo no es tecnológico, sino operativo y legal. Casa Monarca ahora cuenta con una herramienta que le permite demostrar, ante una auditoría o cualquier autoridad, que sus procesos de gestión de accesos son trazables, controlados y alineados con la ley. Para una organización que trabaja con datos de personas en situación vulnerable, esto no es un detalle menor: representa la diferencia entre operar con certeza jurídica o exponerse a sanciones que podrían comprometer su continuidad.

Estado actual

El sistema se encuentra en una versión 1.0 funcional y desplegable en entorno local. La base de datos utilizada es SQLite, lo que lo hace ligero y fácil de instalar, aunque también marca el límite natural de esta etapa. El código está documentado, versionado en Git y distribuido bajo licencia MIT. Los módulos de pruebas están estructurados, aunque todavía pendientes de implementarse por completo. La arquitectura fue diseñada pensando en iteraciones futuras, incluyendo la posibilidad de migrar hacia infraestructura compartida o, en etapas más maduras, hacia esquemas basados en Blockchain.

Objetivos vs Resultados

Qué se cumplió

Los cuatro objetivos centrales del reto se cumplieron de forma completa: el alta, la revocación, la baja y el rastreo de identidades están operativos. Se implementó la jerarquía de roles solicitada, la generación automática de certificados X.509, el cifrado de claves privadas en reposo y el log de auditoría con trazabilidad total. Adicionalmente, se entregó algo que no estaba explícitamente solicitado, pero que aporta un valor real: un dashboard web funcional que permite a cualquier administrador operar el sistema sin tocar una sola línea de código ni conocer la API.

Qué se modificó o adaptó con respecto a los objetivos iniciales

El documento del reto contemplaba certificados para todos los niveles de acceso. Durante el desarrollo, se tomó la decisión técnica de emitir certificados X.509 únicamente para los roles Admin y Coordinator, ya que son quienes realmente firman y autorizan documentos dentro de la organización. Los roles Operative y External se autentican mediante contraseña y JWT, lo cual resulta suficiente para sus necesidades operativas y evita una complejidad innecesaria. También se incorporaron certificados efímeros —usuarios temporales con acceso limitado en minutos u horas—, una funcionalidad no contemplada originalmente, pero que responde a casos reales de la organización, como visitas de auditores o proveedores externos.

Pendientes para siguientes versiones

Quedan abiertos tres frentes para la siguiente iteración. Primero, migrar de SQLite a un motor de base de datos con soporte multiusuario real, como PostgreSQL. Segundo, implementar autenticación multifactor, mencionada en el reto como deseable y aún ausente. Tercero, completar la suite de pruebas automatizadas: el directorio tests/ existe, pero permanece vacío, lo que representa un riesgo para el mantenimiento a largo

plazo. Como horizonte más amplio, la arquitectura ya está diseñada para escalar hacia otros módulos del reto, como el gestor de documentos o el sistema de firma de correos.

Solución Implementada

Qué hace la aplicación realmente

La aplicación controla quién entra, qué puede hacer y cuándo deja de tener acceso dentro del sistema digital de Casa Monarca. Cuando un colaborador se incorpora, el administrador lo registra y el sistema genera automáticamente un par de llaves criptográficas y un certificado digital a su nombre. Cuando esa persona deja la organización o su situación cambia, el administrador revoca o elimina su acceso en cuestión de segundos. Cada una de esas acciones queda registrada con fecha, responsable y descripción. Todo esto ocurre desde una interfaz web sencilla, sin comandos ni configuraciones técnicas de por medio.

Usuarios que la utilizan e impacto generado

Existen dos tipos de usuarios. Por un lado, el administrador del sistema, quien gestiona altas, bajas y revocaciones, además de contar con visibilidad completa del historial de auditoría. Por otro, los colaboradores, que simplemente inician sesión con sus credenciales y operan dentro de los límites permitidos por su rol. El impacto más concreto es que la organización deja de depender de la memoria o del criterio individual para determinar quién tiene acceso activo. Esto reduce el riesgo de accesos no autorizados, facilita cualquier proceso de auditoría y coloca a Casa Monarca en una posición mucho más sólida frente a sus obligaciones legales en materia de protección de datos.

Alcance final de la aplicación.

La aplicación cubre íntegramente el primer sistema del reto: la gestión del ciclo de vida de identidades digitales con soporte criptográfico real. No gestiona documentos, no firma correos ni administra bases de datos; esos son módulos independientes definidos en el reto para otros equipos o versiones futuras. Lo que sí hace, lo realiza de manera completa: gestionar identidades, certificados, roles, auditoría y una interfaz operativa. Se trata de una base sólida sobre la cual puede construirse el resto del ecosistema de seguridad de Casa Monarca.

Impacto de Negocio

Ahorro generado (tiempo/dinero)

Antes de esta solución, gestionar el acceso de un colaborador implicaba coordinar manualmente entre distintas áreas, sin un proceso definido ni un registro centralizado. Cada alta o baja dependía de una comunicación informal y de que alguien recordara actualizar lo que fuera necesario. Con el sistema, ese proceso toma menos de dos minutos desde la interfaz. Para una organización que incorpora o desvincula colaboradores con cierta frecuencia, esto representa horas de trabajo administrativo recuperadas cada mes, sin costos de licencias, sin infraestructura externa y sin depender de un proveedor de software externo.

Incremento en productividad

El impacto en la productividad no proviene de hacer las cosas más rápido, sino de eliminar la incertidumbre. Antes, nadie podía responder con certeza inmediata quién tenía acceso activo y desde cuándo. Ahora, esa información está disponible a un clic dentro del dashboard. Los coordinadores y administradores dejan de invertir tiempo en rastrear información dispersa o en resolver dudas sobre el estado de un colaborador. Ese tiempo liberado, aunque parezca mínimo por evento, se acumula de forma significativa en una organización donde los recursos humanos son limitados y cada hora cuenta.

Reducción de errores o riesgos

El riesgo más crítico que se reduce es el de acceso no autorizado por omisión; es decir, que alguien continúe teniendo acceso simplemente porque nadie procesó su baja a tiempo. Ese escenario, que antes era perfectamente posible, ahora requiere una decisión deliberada de no revocar el acceso. Además, al

cifrar las claves privadas en reposo y registrar cada acción en el log de auditoría, se eliminan dos vectores de riesgo adicionales: la exposición de material criptográfico y la falta de trazabilidad ante un incidente. Para una organización que maneja datos de personas vulnerables, reducir esos riesgos tiene un valor que va mucho más allá de lo operativo.

Lecciones y Hallazgos

Qué funcionó bien

La decisión de construir todo sobre estándares abiertos y bien documentados fue acertada. Utilizar RSA, X.509 y JWT no solo garantiza interoperabilidad futura, sino que también hace que el código sea auditable por cualquier persona con conocimientos básicos de criptografía. Asimismo, funcionó adecuadamente la separación clara entre capas: la lógica criptográfica, la base de datos y la interfaz viven en módulos independientes, lo que vuelve al sistema mantenible sin necesidad de comprender todo al mismo tiempo. El dashboard embebido resultó ser una decisión práctica especialmente valiosa: eliminó la brecha entre la API y el usuario final sin añadir complejidad al despliegue.

Qué se puede mejorar

El punto más evidente es la ausencia de pruebas automatizadas. El directorio existe, pero permanece vacío, lo que significa que cualquier cambio futuro en el código se realiza sin una red de seguridad. Relacionado con esto, la versión actual genera una nueva CA raíz cada vez que se emite un certificado, en lugar de mantener una CA persistente y centralizada, lo cual es funcionalmente correcto, pero criptográficamente poco ortodoxo para un entorno de producción real. Ambos aspectos pueden abordarse en la siguiente iteración sin necesidad de rediseñar la arquitectura existente.

Riesgos detectados

El riesgo detectado es de escalabilidad: SQLite funciona bien para un equipo pequeño, pero no está diseñado para accesos concurrentes intensivos. Si la organización crece o el sistema se comparte con otras OSF, ese límite comenzará a notarse antes de lo esperado.

Estado Actual y Próximos Pasos

Estado:

[productivo / piloto / escalamiento]

El sistema se encuentra en etapa de piloto funcional. Está listo para instalarse y operarse en un entorno controlado, con un equipo pequeño y bajo supervisión técnica cercana. Aún no es una solución de producción completa: le faltan pruebas automatizadas, una base de datos robusta y el endurecimiento de seguridad necesario antes de exponerse a un entorno con múltiples usuarios simultáneos o datos reales de colaboradores. Dicho esto, todo lo que el sistema promete hacer, lo realiza correctamente. Es una base sólida, honesta en sus alcances y construida para crecer.

Recomendaciones:

- *Mejoras:* La prioridad número uno antes de cualquier despliegue real es reemplazar la SECRET_KEY por un valor seguro y único, almacenado como variable de entorno y nunca dentro del código. La segunda mejora urgente consiste en implementar una CA raíz persistente: actualmente se genera una nueva con cada certificado emitido, lo cual funciona, pero no es lo adecuado para un sistema que necesita validar certificados a lo largo del tiempo. Finalmente, poblar la suite de pruebas con pytest es indispensable para que el equipo que tome el relevo pueda realizar cambios con confianza.
- *Nuevas funcionalidades:* La autenticación multifactor representa el siguiente paso natural en materia de seguridad y está mencionada explícitamente en el documento del reto como una funcionalidad deseable. Incorporarla no requiere rediseñar el sistema, sino únicamente añadir una capa sobre el flujo de login existente. Otra funcionalidad valiosa sería la notificación automática al administrador cuando un certificado esté próximo a vencer, evitando que los colaboradores pierdan acceso por descuido.

También vale la pena explorar la exportación del log de auditoría en formato PDF o CSV, lo que facilitaría enormemente los procesos de reporte ante autoridades o durante ejercicios relacionados con los Derechos ARCO.

- *Escalabilidad*: Migrar de SQLite a PostgreSQL es el cambio estructural más importante para cuando el sistema supere la etapa piloto. Esto no implica reescribir la lógica de negocio, sino únicamente actualizar la cadena de conexión en database.py y ajustar el despliegue. En paralelo, contenerizar la aplicación con Docker permitiría que otras organizaciones similares a Casa Monarca adopten el sistema sin fricción técnica, que es precisamente el horizonte de impacto planteado por el reto desde su introducción. La arquitectura actual ya lo permite; solo falta dar el siguiente paso.

Referencias

CASA MONARCA. (s.f.) INICIO. CASA MONARCA. <https://casamonarca.org.mx/>

Inteligencia artificial

Se utilizó la inteligencia artificial Chat GPT para corregir la ortografía, gramática, puntuación, coherencia, cohesión, y adecuación. Los prompts que se utilizaron y las respuestas de la inteligencia artificial Chat GPT se encuentran en el siguiente enlace:

<https://chatgpt.com/share/69fbb746-c428-83e8-b818-2901c6471fb4>